

Lateral Movement Across Cloud Workloads response

Cloud · **Critical** severity · SOC IR Playbook

Incident type	Cloud Intrusion - Lateral Movement
Severity	Critical
Priority	Critical
Detection sources	SIEM, CSPM, EDR on cloud workloads, Cloud Audit Logs, NDR, Threat Intel Feeds

Scenario

An attacker gains a foothold in one cloud workload (e.g., EC2, Azure VM, Kubernetes pod or container) and moves laterally by leveraging over-permissive roles, unsecured credentials, shared storage or misconfigured network rules to reach other workloads or services.

MITRE ATT&CK

T1021, T1086.001, T1534, T1570

Preparation

Enforce network segmentation Use security groups, NSGs or VPC firewalls to restrict east-west traffic Enable workload logging Activate OS logs, CloudTrail, Azure Activity Logs, GCP Audit Logs and flow logs Deploy EDR/EDR for cloud Install endpoint protection or runtime security tools (e.g., Falcon, XDR, Wiz Runtime) Limit IAM role reuse Ensure minimal sharing of roles/permissions across workloads Harden images and infrastructure Use secure images and enforce IaC best practices

Detection & Analysis

Alert triggered Suspicious inter-instance communication, credential use or lateral command execution Identify entry point Locate the initial compromised workload or credential source Trace lateral path Review cloud flow logs, audit trails and EDR logs for signs of SSH, API calls, remote access Analyse tools used Was movement done via scripts, stolen tokens, RDP/SSH or cloud-native APIs?

Containment

Isolate affected workloads Remove compromised instances/pods from the network or scale down affected services Disable involved credentials or roles Immediately revoke tokens, keys or IAM roles used in lateral movement Block east-west traffic temporarily Apply strict ACLs to prevent further movement while analysing scope Alert platform and application owners Notify relevant teams about affected environments

Eradication

Terminate compromised instances or containers Rebuild using trusted images and validated IaC templates Rotate affected credentials Reissue cloud access keys, service principals and user passwords involved Remove backdoors or persistence Check cron jobs, startup scripts, IAM roles or installed malware Fix network/security group rules Prevent recurrence by enforcing least-access models

Recovery

Re-deploy clean workloads From verified pipelines or hardened base images Restore network trust zones Gradually re-enable east-west communication with strict controls Re-enable affected services Only after thorough validation and logging is in place Increase monitoring on recovery assets Use SIEM and runtime tools to validate clean operation

Lessons Learned & Reporting

Document lateral movement path Include accessed systems, tools used, timeline and exposed data Update detection logic Add indicators of compromise and new behavioural rules for lateral movement Harden IAM and network design Apply tighter segmentation, SSO constraints and token binding techniques Conduct internal debrief

Review with security, cloud ops, DevOps and compliance teams Report if necessary To regulators or customers, especially if sensitive data or production systems were compromised

Tools typically involved

SIEM (e.g., Sentinel, Splunk, QRadar); CSPM (e.g., Wiz, Prisma Cloud, Defender for Cloud); Cloud EDR (e.g., CrowdStrike, Cortex XDR, Falco for containers); Cloud audit logs (AWS CloudTrail, Azure Activity Logs, GCP Audit Logs); Network visibility (e.g., VPC Flow Logs, Azure NSG flow logs); SOAR tools for response orchestration

Success metrics (SLA targets)

Detection Time <15 minutes from lateral movement start Isolation Time <30 minutes from detection Credential Rotation Time <2 hours from confirmation Affected Asset Recovery Time Within 48 hours Post-Mortem Report Completion Within 3 business days